

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-07-06 · Run: PR #63 (`fix/depSCAN-20260706-062730` @ `5190938`) · Health Score: **52 / 100** (projected after this PR merges) **Grade C — needs attention**

Executive summary

- **24** dependencies scanned (23 resolved + 1 unresolvable typosquat) on `main` @ `61ed8c3` · **77** dependency×CVE findings (18 CRITICAL-severity, 43 HIGH, 15 MEDIUM, 1 LOW) · 8 outdated deps · 2 license violations.
- **This run's PR (#63)** removes the typosquatted `jackson-databind` coordinate and the untrusted HTTP mirror repository, and clears CVEs on **5 dependencies**: `log4j-core` / `log4j-api` (Log4Shell), `jackson-databind`, `protobuf-java` (transitive), `commons-io`, `commons-lang3`.
- **Newly-disclosed CVEs found mid-run**: Stage 4's live NVD/Grype re-check surfaced **CVE-2026-54512 / CVE-2026-54513** (CVSS 8.1 each) against `jackson-databind` even at the Stage 2-recommended target `2.13.4.2` — this fix version is now **stale** relative to live NVD data. `mysql-connector-java:8.0.30`'s `CVE-2023-22102` (CVSS 8.3) was also confirmed unresolved.
- **Supply-chain verdict: BLOCK** — typosquat and untrusted-mirror findings are now clean (fixed in this PR), but the GPL-2.0-with-FOSS-exception license on `mysql-connector-java` (#58) remains, and per the `depSCAN-supplychain-audit` policy a denied license is an unconditional block regardless of which PR it originated on.
- **Gate outcome on PR #63: BLOCK** — tests PASS (2/2); CVE check FAILs (3 unresolved HIGH); supply-chain check FAILs (license). Evidence posted: [review #4633512001](#).
- **Systemic note**: `main` has not changed since the demo was seeded — every prior daily run (PRs #4 through #61, 25+ runs) opened a similar consolidated fix PR and none has been merged, so `main` still carries the full original CVE/license/supply-chain exposure today. The health score below reflects what *would* land if PR #63 merged, not the current state of `main`.

Health score breakdown

State	CRITICAL CVE	HIGH CVE	MEDIUM CVE	Supply-chain BLOCK findings	Outdated-major deps	Score
Before this run (<code>main</code> @ <code>61ed8c3</code>)	0 (–0)	4 — <code>log4j-core</code> , <code>log4j-api</code> , <code>jackson-databind</code> , <code>protobuf-java</code> (–32)	3 — <code>guava</code> , <code>commons-io</code> , <code>commons-lang3</code> (–6)	3 — typosquat, untrusted mirror, license (–30)	2 — <code>guava</code> , <code>junit-jupiter</code> (–6)	26 / 100 Grade D
After PR #63 merges (projected, per Stage 4 Grype re-scan)	0 (–0)	3 — <code>jackson-databind</code> ×2 (CVE-2026-54512/54513), <code>mysql-connector-java</code> (CVE-2023-22102) (–24)	4 — Grype MEDIUM findings on remaining tree (–8)	1 — <code>mysql-connector-java</code> GPL-2.0 license, still open (–10)	2 — <code>guava</code> , <code>junit-jupiter</code> , still MAJOR_REVIEW (–6)	52 / 100 Grade C

The typosquat + untrusted-mirror removal and the 5 dependency bumps in this PR account for a **+26-point** jump (26 → 52). The remaining gap to Grade A is: 2 newly-disclosed `jackson-databind` CVEs that outran the Stage 2 fix target, the un-fixed `mysql-connector-java` CVE (no version bump was attempted since the license blocks it regardless), the standing GPL-2.0 license violation, and the two deferred major-version reviews (`guava`, `junit-jupiter`).

Top risks (ranked, current `main` state)

Coordinate	Risk	Band	Top CVE	Status
<code>com.fastxml.jackson.core:jackson-databind</code> (typosquat)	—	CRITICAL	n/a (supply-chain)	removed in PR #63

org.apache.logging.log4j:log4j-core / -api	7.8	HIGH	CVE-2021-44228 (Log4Shell, CVSS 10.0)	fixed in PR #63 → 2.26.1
com.fasterxml.jackson.core:jackson-databind	7.8	HIGH	CVE-2019-14379; CVE-2026-54512/54513 still present at 2.13.4.2 (fix 2.18.8+)	partially fixed in PR #63 → needs a further bump, tracked via gate BLOCK
com.google.protobuf:protobuf-java (transitive)	6.7	HIGH	CVE-2024-7254	fixed in PR #63 → 3.25.5 (dependencyManagement pin)
com.google.guava:guava	5.5	MEDIUM	CVE-2023-2976	MAJOR_REVIEW — issue #53 (+15 prior duplicates)
commons-io:commons-io	5.2	MEDIUM	CVE-2021-29425	fixed in PR #63 → 2.14.0
org.apache.commons:commons-lang3	5.2	MEDIUM	CVE-2025-48924	fixed in PR #63 → 3.18.0
mysql:mysql-connector-java	2.5	HIGH (CVE) / BLOCK (license)	CVE-2023-22102 (CVSS 8.3); GPL-2.0 license violation	not fixed — tracked in #58 (+11 prior duplicates), blocks every PR
Untrusted HTTP mirror (internal-untrusted-mirror)	—	BLOCK	n/a (supply-chain)	removed in PR #63
org.junit.jupiter:junit-jupiter	1.7	LOW	n/a (staleness)	MAJOR_REVIEW — new issue #62

Remediation activity — PR #63

Dependency	Change	CVEs cleared	Notes
com.fastxml.jackson.core:jackson-databind	removed	n/a (typosquat)	unresolvable coordinate, dependency-confusion attack vector
internal-untrusted-mirror repository	removed	n/a (supply-chain)	plain-HTTP, non-Central Maven repo
log4j-core / log4j-api	2.14.1 → 2.26.1	CVE-2021-44228, CVE-2021-45046, CVE-2021-45105, CVE-2021-44832	lockstep bump
jackson-databind	2.9.8 → 2.13.4.2	CVE-2019-14379 and other polymorphic-deserialization RCEs	insufficient — CVE-2026-54512/54513 (disclosed after Stage 2 scored this fix) still present; needs 2.18.8+
protobuf-java (transitive via mysql-connector-java)	3.19.4 → 3.25.5	CVE-2022-3509, CVE-2022-3510, CVE-2024-7254	via dependencyManagement pin
commons-io	2.4 → 2.14.0	CVE-2021-29425, CVE-2024-47554	
commons-lang3	3.4 → 3.18.0	CVE-2025-48924	
guava	(unchanged)	—	MAJOR_REVIEW, 8-release API-breakage risk → issue #53
junit-jupiter	(unchanged)	—	MAJOR_REVIEW, JUnit 5 → 6 → new issue #62
mysql-connector-java	(unchanged)	—	version bump alone doesn't clear the GPL-2.0 license → routed to #58

Build: mvn clean test package — **PASS** (2/2 tests, 0 failures). mvn dependency:tree confirmed every bumped coordinate resolves to its target, with protobuf-java shown as "version managed from 3.19.4" to 3.25.5. mvn clean verify still fails on the pre-existing JaCoCo 80%-coverage gate (issue #6 in the demo pom) — unrelated to this PR, present on main beforehand.

Gate (Stage 4) — final verdict: BLOCK

Check	Result	Detail
Unit tests	PASS	2/2 passed, 0 failed
OWASP/NVD CVE (0 CRITICAL/HIGH unresolved)	FAIL	jackson-databind CVE-2026-54512/54513 (CVSS 8.1, fix 2.18.8+); mysql-connector-java CVE-2023-22102 (CVSS 8.3, fix 8.2.0+)
Supply-chain audit (Grype + SBOM)	FAIL (BLOCK)	Typosquat and untrusted-repo checks now clean; GPL-2.0 license on mysql-connector-java remains, unconditional BLOCK per policy

Required follow-up actions, in order: (1) bump `jackson-databind` to $\geq 2.18.8$; (2) bump `mysql-connector-java` to $\geq 8.2.0$ to clear CVE-2023-22102; (3) separately resolve the GPL-2.0 license — replace the driver (e.g. MariaDB Connector/J) or obtain a policy exception (#58). Neither `guava` (#53) nor `junit-jupiter` (#62) block this gate — both are non-CVE or sub-HIGH findings routed to MAJOR_REVIEW.

Trend vs. previous run

- **2026-07-05 (PR #61, unmerged):** projected health score 64/100 (Grade C) after fixing `log4j`, `jackson-databind` ($\rightarrow 2.18.8$), `guava` ($\rightarrow 32.0.0-jre$), `commons-lang3`, `commons-io` — a larger batch than today's, but still gated BLOCK on the standing `mysql` license + `untrusted-mirror` findings.
- **2026-07-06 (PR #63, this run):** projected 52/100 (Grade C) — lower than PR #61's projection because this run's batch did not include the `guava` major bump, and Stage 2's `jackson-databind` target (2.13.4.2) had already fallen behind newly-disclosed CVEs by gate time. `Untrusted-mirror` is now fixed (PR #61 hadn't removed it); the license violation remains the common blocker across both runs.
- **main itself has not moved:** it is still at the Day-1 baseline (26/100, Grade D) because no fix PR has ever been merged. The persistent gap between "PR is ready" and "PR gets merged" is the actual bottleneck this pipeline is surfacing, not the auto-remediation logic.

Aggregated from `depscan-report.json`, `depscan-risk-report.json`, PR #63, and the Stage 4 merge-gate verdict. Generated by the Dependency & Supply-Chain Plugin — Stage 5.